

SYS.5.1 Blockchain und Distributed Ledger Technologien

1 Beschreibung

1.1 Einleitung

Die Blockchain in Verbindung mit Distributed Ledger Technologien (DLT) ist ein dezentraler Ansatz für eine fälschungssichere, unveränderliche, redundante und nachvollziehbare Bereitstellung von Informationen in einem Netzwerk gleichberechtigter Peers ohne zentrale Instanz.

Das fälschungssichere und unveränderliche Speichern von Informationen findet in der Blockchain mittels kryptografischer Verfahren wie beispielsweise digitaler Signaturen und kryptografischer Hashfunktionen statt. Nachvollziehbarkeit erreicht die Blockchain über die Verkettung ihrer Hashblöcke, wodurch Änderungen an jeder Position auffallen.

Distributed Ledger Technologien sorgen mithilfe von Public-Key-Verfahren, verteilten Peer-to-Peer-Netzwerken (P2P) sowie einem Konsensalgorithmus für Redundanz und Einheitlichkeit unter den verteilten Datenstrukturen. Sie sorgen damit für Dezentralität ohne die Einbindung einer zentralen Autorität. Der Konsensalgorithmus stellt in diesem Rahmen sicher, dass sich alle Teilnehmenden im Netzwerk über den aktuellen Status der Blockchain einig sind.

Eine weitere Fähigkeit ist die Fehlertoleranz (Fault Tolerance). In Bezug auf Blockchain und DLT besteht sie darin, dass das Netzwerk robust gegenüber ausfallenden oder fehlerhaften Knoten ist, um Integrität, Verfügbarkeit, Authentizität und Nichtabstreitbarkeit zu gewährleisten. Zur Automatisierung existiert in vielen Blockchains die Möglichkeit, Smart Contracts (intelligente, selbstausführende Verträge) zu verwenden. Diese sind automatisierte Programme bzw. eine Form von Software, die auf einer Blockchain-Plattform automatisch Aktionen ausführt, sobald bestimmte Bedingungen erfüllt sind.

Geltungsbereiche (Cluster-Modellierung):

Um möglichst allgemeingültig zu bleiben, lassen sich Blockchains und DLT in Abhängigkeit ihrer Merkmale in Geltungsbereiche bzw. Cluster einteilen. Die in diesem Baustein referenzierten Cluster (0 bis 4) fassen jeweils bestimmte Blockchain-Ausprägungen zusammen (Cluster 0: stark dezentralisiert, PoW, langsame TPS; Cluster 1: On/Off-Chain, PoS, mäßig schnell; Cluster 2: B2B, programmierbar, langsame TPS; Cluster 3: B2B/B2C, programmierbar, Token-basiert; Cluster 4: Plugable, mäßig dezentralisiert). Je nach Anforderung wird darauf verwiesen, für welche Cluster sie maßgeblich ist.

1.2 Zielsetzung

Ziel dieses Bausteines ist es, den Einsatz einer Blockchain und DLT abzusichern und zu

erleichtern, um Integrität, Verfügbarkeit, Authentizität, Vertraulichkeit und die Unveränderlichkeit aufgrund der Verkettung der Blöcke unter Verwendung des Hash-Wertes zu gewährleisten. Dazu stellt dieser Baustein Anforderungen bereit, um spezifischen Gefährdungen entgegenzuwirken und die Blockchain und DLT sicher zu betreiben. Er richtet sich an Informationssicherheitsbeauftragte (ISB) der jeweiligen Institutionen sowie an Administrierende von Blockchains und DLT, wodurch Sicherheitsanforderungen gemäß dem Security-by-Design-Ansatz so früh wie möglich bereits bei der Planung und der Entwicklung berücksichtigt werden können.

1.3 Abgrenzung und Modellierung

Der Baustein SYS.5.1 Blockchain und Distributed Ledger Technologien ist einmal auf jedem Knoten im Peer-to-Peer-Netzwerk (P2P) der Distributed Ledger Technologie anzuwenden, auf dem eine dezentrale Kopie einer Blockchain vorhanden ist. Er ist immer anzuwenden, sobald eine Blockchain und Distributed Ledger Technologien unabhängig vom Typ oder Cluster zum Einsatz kommen.

Dieser Baustein behandelt allgemeine Sicherheitsaspekte von Blockchain und Distributed Ledger Technologien, Anforderungen zur Abdeckung der wichtigsten Angriffsvektoren sowie eine Betrachtung der DLT in Clustern, unabhängig vom eingesetzten Produkt. Produktspezifische Sicherheitsaspekte und Lösungen, die auf einer DLT als weiterer Layer aufsetzen, werden hier nicht behandelt.

Um ein IT-Grundsicherheits-Modell für einen konkreten Informationsverbund zu erstellen, muss grundsätzlich die Gesamtheit aller Bausteine betrachtet werden. Folgende Inhalte sind eng mit dem Thema verbunden und werden in anderen Bausteinen behandelt:

- Absicherung und Umgang mit Hardware → INF.1 Allgemeines Gebäude, INF.2 Rechenzentrum sowie Serverraum, SYS.1.1 Allgemeiner Server
- Netzwerksicherheit → NET.1.1 Netzarchitektur und -design, NET.3.1 Router und Switches, NET.3.2 Firewall
- Kryptografie und Datensicherheit → CON.1 Kryptokonzept, CON.3 Datensicherungskonzept
- Software und Entwicklung → APP.6 Allgemeine Software, APP.7 Entwicklung von Individualsoftware (auftraggebende Seite), CON.8 Software-Entwicklung (auftragnehmende Seite)
- Allgemeiner Betrieb → OPS.1.1.1 Allgemeiner IT-Betrieb, OPS.1.1.3 Patch- und Änderungsmanagement, OPS.1.1.4 Schutz vor Schadprogrammen, OPS.1.1.6 Software-Tests und -Freigaben
- Identitäten → ORP.4 Identitäts- und Berechtigungsmanagement

2 Gefährdungslage

Die folgenden spezifischen Bedrohungen und Schwachstellen sind für den Baustein SYS.5.1 Blockchain und Distributed Ledger Technologien von besonderer Bedeutung.

2.1 Verlust der Mehrheit

Sollte eine Gruppe von Teilnehmenden über die Mehrheit an Knoten im Netzwerk verfügen und diese dazu verwenden, die Blockchain zu manipulieren, kann dies zu schwerwiegenden Gefährdungen der Integrität führen. Ein solcher Mehrheitsverlust kann auf verschiedene Weise auftreten, wie beispielsweise durch 51%-, Sybil- oder Fork-Angriffe.

2.2 Ausfall oder Manipulation des Netzwerkes

Da in einer DLT zur Konsensbildung der Blockchains die Kommunikation der Knoten elementar ist, stellt der Ausfall oder auch die Manipulation eine große Gefahr dar. Dabei können Teile des Netzwerkes abgespalten (Partitionierungen) oder Kommunikation umgeleitet werden (Routing-Angriffe). Ein Ausfall des Netzwerkes würde eine Konsensbildung der Blockchains unmöglich machen.

2.3 Unsichere oder fehlerhafte Smart Contracts

Da Smart Contracts bei bestimmten Blockchain-Frameworks zum Einsatz kommen, um komplexe Verträge und Transaktionen abzuschließen, können diese wie bei jeder Software fehleranfällig sein. Dies könnte zu gefährlichen Situationen führen, wenn sie fehlerhaft sind oder von bössartigen Akteuren manipuliert werden.

2.4 Gefahren durch Social Engineering

In Blockchains können Social-Engineering-Angriffe zu erheblichen Gefährdungen führen. Netzwerkteilnehmenden, die Opfer solcher Angriffe werden, wird vorgespielt, die angreifende Person sei vertrauenswürdig, um so beispielsweise an Passwörter und private Schlüssel zu gelangen, mit denen nicht rückgängig zu machende Transaktionen oder Manipulationen an der Blockchain durchgeführt werden.

2.5 Missbrauch von Berechtigungen autorisierter Benutzer

Der Missbrauch durch autorisierte Benutzer besteht darin, dass Innentäter unbefugt auf private Schlüssel zugreifen können, die zur Verwaltung von Vermögenswerten oder anderen vertraulichen Informationen in der Blockchain verwendet werden. Mit diesen Privilegien könnten unautorisierte Transaktionen freigegeben oder die Funktionsfähigkeit der Blockchain durch Denial-of-Service-Angriffe beeinträchtigt werden.

2.6 Unsachgemäßer Umgang mit privaten Schlüsseln

Der private Schlüssel dient in einer Blockchain als Identitätsnachweis und kommt einer digitalen Identität gleich. Wenn Anwendende unzureichend sensibilisiert sind, steigt das Risiko des Verlustes oder Missbrauchs dieser Schlüssel. Dies kann dazu führen, dass Angreifende vollen Zugriff auf Werte erhalten und vollständig im Namen des Opfers handeln.

2.7 Angriffe durch Schadsoftware

Angriffe durch Schadsoftware wie Malware oder Ransomware können trotz der dezentralen Natur der Blockchain besonders schwerwiegend sein und sich von einem kompromittierten Knoten schnell im gesamten Netzwerk verbreiten. Im Fokus eines solchen Angriffes stehen in der Regel private Schlüssel.

2.8 Unsichere kryptografische Verfahren

Kommen kryptografische Hashverfahren zur Anwendung, die nicht dem Stand der Technik entsprechen, kann die Integrität und Vertraulichkeit der Blockchain untergraben werden. Wenn ein Angreifer das Urbild oder ein zweites passendes Urbild zu einer signierten Transaktion errechnen kann, können Transaktionen im Namen anderer Teilnehmender ausgeführt werden.

2.9 Unzureichendes Identitäts- und Berechtigungsmanagement

Durch eine unzureichende Identitätsüberprüfung, schwache Authentifizierung oder fehlerhafte Berechtigungsverwaltung in einer Blockchain kann es zu unbefugtem Zugriff, unberechtigter Rechteausweitung und Datenmanipulation kommen.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins SYS.5.1 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Informationssicherheitsbeauftragter (ISB), Fachverantwortliche, Entwickler

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

SYS.5.1.A1 Festlegen einer Mindestknotenanzahl (B)

Vor dem Einsatz einer DLT MUSS eine Mindestanzahl an Knoten (Netzwerkteilnehmende oder Peers) festgelegt werden. Dabei DARF NICHT der vom Hersteller der DLT vorgegebene Mindestwert an Knoten unterschritten werden, um Fehlertoleranz zu gewährleisten. Zusätzlich MUSS ein Puffer über dem Mindestwert zur Erreichung von Fehlertoleranz berücksichtigt werden.

Dieser Puffer MUSS bei sehr kleinen DLTs (≤ 10) bei mindestens 50 % liegen und kann mit steigender Größe des Netzwerkes regressiv fallen. Dabei MÜSSEN Sicherheitsanforderungen,

Verfügbarkeit, Skalierbarkeit, Netzwerktopologie sowie der Konsensmechanismus betrachtet werden.

Darüber hinaus MUSS für jeden Teilnehmenden eine Begrenzung der Anzahl an Knoten festgelegt werden, die von ihm betrieben werden darf, um den Einfluss einzelner Netzwerkteilnehmender zu beschränken. *(Anwendbar auf alle Cluster)*

SYS.5.1.A2 Ausschluss der Speicherung von Daten mit dem Recht auf Vergessenheit (B) [Fachverantwortliche]

In einer Blockchain DÜRFEN KEINE Daten gespeichert werden, die aus rechtlichen oder gesetzlichen Gründen grundsätzlich das Recht auf Vergessenheit bzw. Löschung erfordern. *(Anwendbar auf alle Cluster)*

SYS.5.1.A3 Persistente Speicherung (B)

Zur Erreichung der Persistenz der Daten in einer DLT MÜSSEN die Blockchains dezentral (wiederherstellbar über andere Knoten), konsistent, unveränderbar und dauerhaft gespeichert werden. Dazu MUSS der verwendete Speicher skalierbar, ausfallsicher und performant sein. *(Anwendbar auf alle Cluster)*

SYS.5.1.A4 Speicherung von Passwörtern und Schlüsseln (B)

Passwörter und Schlüssel für eine Blockchain MÜSSEN verschlüsselt gespeichert werden. *(Anwendbar auf alle Cluster)*

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

SYS.5.1.A5 Verteilung der Knoten auf mehrere Standorte (S)

Um eine Verbesserung sowie Erhöhung der Dezentralisierung und Verfügbarkeit zu erreichen, SOLLTEN die Knoten über mehrere Standorte verteilt werden. Um eine georedundante Dezentralisierung zu erreichen, SOLLTEN die Knoten über mehrere Standorte in verschiedenen Städten oder Staaten verteilt werden. *(Relevant für Cluster 1, 2, 3, 4)*

SYS.5.1.A6 Erstellung von Vorgaben und Richtlinien für Smart Contracts (S) [ISB]

Für Smart Contracts SOLLTEN Vorgaben und Richtlinien vor der Inbetriebnahme der Blockchain bzw. DLT festgelegt werden. Diese SOLLTEN Merkmale wie Determinismus, Sicherheit und Verifizierbarkeit, Interoperabilität, Update-Fähigkeit, Transparenz, verteilte Ausführungskosten sowie Compliance-Anforderungen berücksichtigen.

Komplexe Operationen in Smart Contracts SOLLTEN vermieden werden, um verteilte

Ausführungskosten zu minimieren. Dienste, die in die Blockchain eingebunden werden, SOLLTEN bei der Absicherung auf Netzwerk- und Applikationsebene mitberücksichtigt werden. Die Umsetzung SOLLTE regelmäßig auditiert werden. Dies SOLLTE NICHT durch die entwickelnde Person des Smart Contracts selbst durchgeführt werden. *(Relevant für Cluster 2, 3, 4)*

SYS.5.1.A7 Verwendung stabiler und aktueller Software-Versionen (S)

Zum sicheren Betreiben der Blockchain und DLT SOLLTEN nur aktuelle Softwareversionen verwendet werden. Patches und Updates SOLLTEN zeitnah eingespielt werden. Softwareversionen aus Pre-Releases, wie Alpha- oder Beta-Versionen, SOLLTEN NICHT für den Produktivbetrieb verwendet werden. *(Anwendbar auf alle Cluster)*

SYS.5.1.A8 Einführung einer Zugriffskontrolle (S)

Um den Zugriff auf die Blockchain und DLT zu regulieren bzw. nur autorisierten Nutzenden und Administrierenden zu gewähren, SOLLTE ein System der Zugriffskontrolle und Authentifizierung implementiert werden. Hierzu SOLLTE eine Realisierung über ein Identitätsmanagement, den Konsensalgorithmus oder über Smart Contracts in Betracht gezogen werden. *(Relevant für Cluster 1, 2, 3)*

SYS.5.1.A9 Festlegen von Mindestanforderungen an kryptografische Hashfunktionen (S) [ISB]

Bei der Auswahl von Verschlüsselungsverfahren und Schlüssellängen SOLLTE die Einsatzdauer bewertet und die Technische Richtlinie BSI TR-02102-1 berücksichtigt werden. Die verwendeten kryptografischen Hashfunktionen SOLLTEN dem Stand der Technik entsprechen und mindestens eine Schlüssellänge von 256 Bit aufweisen. Bei einer längeren Einsatzdauer SOLLTEN sie mindestens eine Länge von 512 Bit besitzen. *(Anwendbar auf alle Cluster)*

SYS.5.1.A10 Erstellung eines Planes zur Erhaltung der Langlebigkeit (S)

Im Vorfeld der Inbetriebnahme SOLLTE ein Plan erstellt werden, der regelt, wie mit den Daten der Blockchain zu verfahren ist, wenn die Einhaltung der Vertraulichkeit und Integrität in der Zukunft nicht mehr gewährleistet ist. Für den Fall, dass die Blockchain kompromittiert wurde, SOLLTE für die Community oder den Betreiber die Möglichkeit bestehen, einen Fork der Blockchain zu erstellen. *(Anwendbar auf alle Cluster)*

SYS.5.1.A11 Festlegen von Policies (S) [Fachverantwortliche]

Für die Blockchain und DLT SOLLTEN Policies festgelegt werden, die den Betrieb regeln. Diese SOLLTEN bestimmen, welcher Konsensalgorithmus verwendet wird, wie die Transaktionsvalidierung stattfindet und ob eine Zugriffskontrolle und Schlüsselverwaltung

existiert. *(Anwendbar auf alle Cluster)*

SYS.5.1.A12 Vermeidung von Privileg-Escalation (S)

Zur Vermeidung von Rechteanreicherung (Privilege Escalation) SOLLTEN Sicherheitsmaßnahmen implementiert werden. Dazu SOLLTE eine regelmäßige Überprüfung der Smart Contracts erfolgen und Penetrationstests durchgeführt werden. Es SOLLTE ein robuster Konsensalgorithmus verwendet werden, der eine breite Verteilung der Entscheidungsfindung gewährleistet. *(Anwendbar auf alle Cluster)*

SYS.5.1.A13 Erhöhung des Passwortschutzes (S)

Zum Speichern von Passwörtern für private Schlüssel oder Wallets SOLLTEN kryptografisch starke Salted-Hashverfahren verwendet werden. *(Anwendbar auf alle Cluster)*

SYS.5.1.A14 Erhaltung der Integrität (S)

Es SOLLTEN geeignete Maßnahmen getroffen werden, um die Integrität gegen Angriffe (z. B. Double Spending) zu erhalten. Dazu SOLLTE ein geeigneter Konsensalgorithmus gewählt, eine bestimmte Anzahl an Blöcken bis zur Finalität festgelegt, nur integere Software zugelassen und ein Zeitstempel für die chronologische Reihenfolge verwendet werden. *(Relevant für Cluster 0, 3)*

SYS.5.1.A15 Sicherung der Blockchain Business Continuity (S)

Zur Erhaltung der Verfügbarkeit SOLLTE ein Notfallplan erstellt werden, der Anweisungen für den Umgang mit Störungen der DLT-Infrastruktur enthält. Es SOLLTE ein Monitoring implementiert werden. Im Falle eines Zero-Day-Exploits SOLLTEN für alle Teilnehmenden Reaktionszeiten und die Mindestanzahl an Zustimmungen von Knoten für einen Notfall-Patch festgelegt werden. *(Relevant für Cluster 1, 2, 3, 4)*

SYS.5.1.A16 Entwicklung einer Backup-Strategie (S)

Zur Erhöhung der Verfügbarkeit SOLLTE eine Backup-Strategie entwickelt werden. Dieses dezentrale Backup SOLLTE als Sicherungskopie auf mehrere Knoten verteilt werden. Bei der Implementierung SOLLTEN Dezentralität, Konsistenz (kryptografische Algorithmen) und Synchronisation berücksichtigt werden. *(Relevant für Cluster 1, 2, 4)*

SYS.5.1.A17 Mehr-Faktor-Authentifizierung (S)

Authentifizierungen und digitale Signaturen von unternehmenskritischen Anwendungen SOLLTEN über eine Mehr-Faktor-Authentifizierung (z. B. Hardware-Token oder Authenticator-App) abgesichert werden. *(Anwendbar auf alle Cluster)*

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu

berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse.

SYS.5.1.A18 Multi-Signatur für administrative Tätigkeiten (H)

Die Ausführung von administrativen Tätigkeiten zur Verwaltung und Wartung der Blockchain bzw. der DLT SOLLTE erst nach Zustimmung von mehreren Berechtigten erfolgen. Dazu SOLLTE eine Multi-Signatur (MultiSig) verwendet werden, bei der mehrere Administrierende diese mit ihrem privaten Schlüssel signieren. (I, A)

SYS.5.1.A19 Verwendung von quantensicheren Algorithmen (H)

Es SOLLTEN quantensichere Algorithmen (Post-Quantum-Kryptographie) verwendet werden, wenn eine erhöhte Sicherheit bei der Verwendung kryptografischer Hashverfahren gewährleistet werden muss (siehe BSI-TR-02102-1). (C, I)

SYS.5.1.A20 Trennung von Management- und Applikationsnetzwerk (H)

Als zusätzliche Sicherheitsmaßnahme SOLLTE eine netzwerktechnische Trennung (physisch oder logisch) von Management- und Applikationsnetzwerk implementiert werden. (C, I, A)

4 Weiterführende Informationen

4.1 Wissenswertes

Informationen zum Schlüsselmanagement und zu Algorithmen:

- NIST SP 800-107: "Recommendation for Applications Using Approved Hash Algorithms"
- NIST SP 800-57: "Recommendation for Key Management"
- BSI TR-02102-1: "Kryptographische Verfahren: Empfehlungen und Schlüssellängen"

Zum Thema Blockchain und DLT:

- BSI: "Blockchain sicher gestalten – Konzepte, Anforderungen, Bewertungen"
- BSI: "Eckpunktepapier für DLT-basierte Kryptowährungen"
- NISTIR 8202: "Blockchain Technology Overview"
- ISO 22301:2019 und BSI-Standard 200-4 zum Business Continuity Management.

Kreuzreferenztablette zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein SYS.5.1 von Bedeutung:

- G 0.9 Ausfall oder Störung von Kommunikationsnetzen
- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.22 Manipulation von Informationen
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.30 Unberechtigte Nutzung oder Administration von Geräten und Systemen

- G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- G 0.32 Missbrauch von Berechtigungen
- G 0.39 Schadprogramme
- G 0.40 Verhinderung von Diensten (Denial of Service)
- G 0.42 Social Engineering
- G 0.46 Integritätsverlust schützenswerter Informationen

[illegible]

SY S.5 .1. A6 (S)		X		X	X				X			
SY S.5 .1. A7 (S)					X				X			
SY S.5 .1. A8 (S)			X	X		X	X	X				
SY S.5 .1. A9 (S)		X	X	X								X
SY S.5 .1. A1 0 (S)		X										X
SY S.5 .1. A1 1 (S)		X				X	X					
SY S.5 .1. A1 2				X	X			X				

(S)												
SY S.5 .1. A1 3 (S)			X			X					X	
SY S.5 .1. A1 4 (S)				X	X							X
SY S.5 .1. A1 5 (S)	X				X				X	X		
SY S.5 .1. A1 6 (S)	X									X		X
SY S.5 .1. A1 7 (S)			X	X		X	X	X			X	
SY S.5 .1. A1 8 (H)				X		X		X				

SY S.5 .1. A1 9 (H)		X	X	X								X
SY S.5 .1. A2 0 (H)	X					X			X	X		